

Trusted Agentic Commerce: Manual de Referencia

Manual de referencia: Trusted Agentic Commerce para Magento 2

Versión 1.3.4 · Referencia técnica para desarrolladores e integradores de sistemas

Tabla de contenidos

1. [Arquitectura del módulo](#)
2. [Referencia de configuración](#)
3. [Esquema de base de datos](#)
4. [Eventos y observadores](#)
5. [Trabajos cron](#)
6. [Recursos ACL](#)
7. [Rutas de administración](#)
8. [Rutas de frontend](#)
9. [Servicios](#)
10. [Motor de cumplimiento](#)
11. [Bandeja de salida de webhooks](#)
12. [Verificación de token de agente](#)
13. [Manifiesto MCP](#)
14. [Atributos de extensión](#)
15. [Endpoints de API invocados](#)
16. [Modelo de seguridad](#)

- 17. [Comandos de consola](#)
- 18. [Parches de datos](#)
- 19. [Configuración Di.xml](#)
- 20. [Registro de eventos \(Logging\)](#)

1. Arquitectura del módulo

Trusteed_AgenticCommerce	
├─ Block/Adminhtml/	Bloques SPA para páginas de administración
├─ Console/Command/	Comandos CLI (check-webserver, webhook:status)
├─ Controller/	
│ ├─ Adminhtml/	Controladores de administración
│ └─ Wellknown/	Endpoint /.well-known/mcp.json del frontend
├─ Cron/	Vaciador de webhooks + latido de latencia
├─ Enforcement/	Lógica de la puerta HITL R043
├─ Model/	
│ ├─ Config/	Lectores ScopeConfig + validador SSRF
│ ├─ Manifest/	Constructor del manifiesto MCP
│ ├─ Security/	Firmador HMAC + validador de URL de API
│ ├─ Setup/	Proveedor de datos del asistente de configuración
│ ├─ Storefront/	Detector de temas Hyvä/PWA
│ └─ Webhook/	Repositorio de bandeja de salida + publicador de firma
├─ Observer/	Ganchos de eventos Magento (pedido, envío, pago)
├─ Plugin/	Plugin de atributo de extensión de pedido
├─ Router/	Enrutador de URL /.well-known
├─ Service/	EnforcementClient, AgentTokenVerifier, CartSignals
├─ Setup/Patch/Data/	Parches de datos (atributo EAV, puente Hyvä, evento instalación)
├─ Test/	
│ ├─ Integration/	Suite de pruebas de integración
│ ├─ Static/	Verificador de consistencia de rutas
│ └─ Unit/	Suite de pruebas unitarias
├─ etc/	XML del módulo, DI, ACL, eventos, cron, config del sistema
├─ i18n/	Archivos de traducción
└─ view/	Layout y plantillas del administrador

Nombre del módulo: `Trusteed_AgenticCommerce` Paquete Composer: `trusteed/agentic-commerce-magento` Espacio de nombres PHP: `Trusteed\AgenticCommerce` Versión de configuración: ninguna (usa Data Patches exclusivamente)

2. Referencia de configuración

Todas las rutas están en Tiendas → Configuración → Trusteed → Agentic Commerce (sección `trusteed_general` en `system.xml`).

Grupo: Conexión API (`trusted_general/general`)

Campo	Ruta de Configuración	Tipo	Ámbito	Descripción
API Base URL	<code>trusted_general/general/api_base_url</code>	texto	Global	Raíz de la API de Trusted (debe ser HTTPS). Predeterminado: <code>https://api.trusted.xyz</code>
Merchant ID	<code>trusted_general/general/merchant_id</code>	texto	Global	Asignado por Trusted al crear la cuenta
Integration Token	<code>trusted_general/general/integration_token</code>	oculto	Global	Token Bearer para llamadas API salientes. Almacenado cifrado
Webhook Secret	<code>trusted_general/general/webhook_secret</code>	oculto	Global	Secreto HMAC-SHA256 para firmar entregas de webhook. Almacenado cifrado
Internal HMAC Secret	<code>trusted_general/general/internal_hmac_secret</code>	oculto	Global	Firma las llamadas internas de latido con las cabeceras <code>X-Trusted-Connection-Id</code> , <code>X-Trusted-Timestamp</code> y <code>X-Trusted-Signature</code> . La API de Trusted rechaza el esquema anterior <code>X-Internal-Auth</code>
Webhook Secret Version	<code>trusted_general/general/webhook_secret_version</code>	texto	Global	Incrementa al rotar el secreto de webhook. Se usa en la cabecera <code>X-Trusted-Webhook-Secret-Version</code>

Campo	Ruta de Configuración	Tipo	Ámbito	Descripción
Connection ID	<code>trusted_general/general/connection_id</code>	texto	Sitio web	Asignado por Trusted al conectar. Identifica esta tienda en la entrega de webhooks

Grupo: Características (`trusted_general/features`)

Campo	Ruta de Configuración	Tipo	Ámbito	Descripción
Enable WebMCP Bridge	<code>trusted_general/features/webmcp_enabled</code>	selección	Sitio web	Inyecta el puente JS del storefront. Se desactiva automáticamente en Hyvä/PWA Studio
Enable Phase B	<code>trusted_general/features/phase_b_enabled</code>	selección	Global	Reservado para futura SPA embebida. No activar

Rutas de cumplimiento

Ruta de Configuración	Descripción
<code>trusted/enforcement/failure_mode</code>	<code>observe</code> o <code>enforce</code> . Predeterminado: <code>enforce</code> . Puede cambiarlo en Trusted → Ajustes
<code>trusted/enforcement/installation_id</code>	Enforcement Installation ID que proporciona Trusted. Se introduce en el Asistente de Configuración
<code>trusted/enforcement/hmac_secret</code>	Enforcement HMAC Secret que proporciona Trusted, usado para firmar <code>POST /v1/rules/evaluate</code> . Se introduce en el Asistente de Configuración

3. Esquema de base de datos

Tabla: `trusteed_webhook_outbox`

Bandeja de salida de entrega fiable para eventos de pedido. Las entradas son creadas por observadores y vaciadas cada minuto por el cron `trusteed_webhook_drain`.

Columna	Tipo	Nulable	Descripción
<code>id</code>	int unsigned AUTO_INCREMENT	No	Clave primaria
<code>event_id</code>	varchar(36) UNIQUE	No	Identificador de evento UUID v4 (clave de idempotencia)
<code>event_type</code>	varchar(32)	No	<code>order_created</code> , <code>order_completed</code> , <code>order_refunded</code> , <code>order_cancelled</code> , <code>order_fulfilled</code>
<code>entity_id</code>	int unsigned	No	<code>entity_id</code> del pedido Magento
<code>increment_id</code>	varchar(32)	No	ID de incremento del pedido Magento (p. ej., <code>000000001</code>)
<code>composite_id</code>	varchar(64)	No	ID compuesto en formato <code>MAG:<entity_id></code>
<code>store_view_code</code>	varchar(32)	No	Código de vista de tienda en el momento del evento
<code>payload</code>	text	No	Payload del pedido serializado (JSON)
<code>status</code>	varchar(16)	No	<code>pending</code> , <code>delivered</code> , <code>dead</code>
<code>retry_count</code>	int unsigned	No	Número de intentos de entrega. Predeterminado: 0
<code>secret_version</code>	int unsigned	No	Versión del secreto de webhook al encolar
<code>next_attempt_at</code>	timestamp	Sí	Hora mínima de entrega elegible (retroceso exponencial). NULL = elegible inmediatamente
<code>locked_until</code>	timestamp	Sí	Vencimiento del bloqueo de arrendamiento (mecanismo de bloqueo de trabajador)
<code>locked_by</code>	varchar(64)	Sí	Identificador del proceso que mantiene el arrendamiento

Columna	Tipo	Nulable	Descripción
<code>created_at</code>	timestamp	No	Hora de creación de la entrada
<code>updated_at</code>	timestamp	No	Hora de última modificación (actualización automática)

Índices:

- `TRUSTEED_WEBHOOK_OUTBOX_EVENT_ID` (UNIQUE) en `event_id`
- `TRUSTEED_WEBHOOK_OUTBOX_STATUS_CREATED_AT` en `(status, created_at)`
- `TRUSTEED_WEBHOOK_OUTBOX_LOCKED_UNTIL` en `locked_until`
- `TRUSTEED_WEBHOOK_OUTBOX_STATUS_NEXT_ATTEMPT` en `(status, next_attempt_at, created_at)`

Columnas añadidas a `sales_order`

Columna	Tipo	Descripción
<code>trusted_receipt_uri</code>	varchar(1024) nulable	URI del TrustReceipt. Inmutable una vez establecido
<code>trusted_receipt_status</code>	varchar(16) nulable	<code>signed</code> . Se establece al guardar por primera vez la URI del recibo

4. Eventos y observadores

Evento Magento	Clase Observador	Propósito
<code>sales_order_save_after</code>	<code>SalesOrderSaveAfter</code>	Encola eventos <code>order_created</code> (pedidos nuevos, en proceso y en espera), <code>order_completed</code> , <code>order_refunded</code> (pedidos cerrados) y <code>order_cancelled</code> según el estado del pedido
<code>sales_order_creditmemo_save_after</code>	<code>SalesCreditmemoSaveAfter</code>	Encola <code>order_refunded</code> para reembolsos parciales
<code>sales_model_service_quote_submit_before</code>	<code>CheckoutSubmitBefore</code>	Cumplimiento pre-pedido: verifica el token del agente, llama a <code>/v1/rules/evaluate</code> , aplica congelación HITL (R043) o lanza <code>LocalizedException</code> en BLOCK
<code>sales_order_payment_failed</code>	<code>SalesOrderPaymentFailedObserver</code>	Envía una señal de fallo de checkout firmada con HMAC a <code>/api/v1/checkout-failures</code> para el seguimiento de R011. No usa la bandeja de salida
<code>sales_order_shipment_save_after</code>	<code>ShipmentSaveAfter</code>	Encola <code>order_fulfilled</code> cuando se crea un envío

Plugins

Clase Plugin	Objetivo	Método	Tipo	Propósito
<code>OrderRepositoryPlugin</code>	<code>Magento\Sales\Api\OrderRepositoryInterface</code>	<code>get</code>	after	Carga los atributos de la extensión <code>trusteded_repository</code> al cargar el pedido
<code>OrderExtensionAttribute</code>	<code>Magento\Sales\Api\OrderRepositoryInterface</code>	<code>save</code>	around	Persiste los atributos de la extensión al guardar el pedido

5. Trabajos cron

Ambos trabajos están en el grupo cron `default` y se ejecutan cada minuto.

`trusteded_webhook_drain`

Clase: `Trusteed\AgenticCommerce\Cron\DrainOutbox`

Procesa la tabla `trusteded_webhook_outbox`:

- Selecciona entradas donde `status = 'pending'` Y (`next_attempt_at IS NULL` O `next_attempt_at ≤ NOW()`) Y (`locked_until IS NULL` O `locked_until < NOW()`)
- Adquiere un arrendamiento (`locked_by = <worker-id>` , `locked_until = NOW() + 60s`)
- Hace POST del payload a `POST /api/v1/webhook/magento/<connection_id>` con las cabeceras de firma descritas en [Bandeja de salida de webhooks](#)
- En éxito (2xx): establece `status = 'delivered'`
- En fallo: incrementa `retry_count`, establece un `next_attempt_at` exponencial (2 s × 2^{retry_count}, con tope de 1 hora y una variación aleatoria de ±20 %)
- Tras 8 reintentos: establece `status = 'dead'`

`trusteded_lag_heartbeat`

Clase: `Trusteed\AgenticCommerce\Cron\EmitLagHeartbeat`

Cada minuto, calcula la antigüedad de la entrada `pending` más antigua de la bandeja de salida y la informa a `POST /api/v1/internal/magento/lag-heartbeat` para que el panel de Trusteed pueda alertar sobre latencias de entrega.

6. Recursos ACL

ID de Recurso	Título	Notas
<code>Trusteed_AgenticCommerce::config</code>	Trusteed Agentic Commerce	Concede acceso a todas las páginas de administración de Trusteed
<code>Trusteed_AgenticCommerce::token</code>	Trusteed Embed Token Relay	Concede acceso al controlador de emisión de tokens usado por el Asistente de Configuración

Para conceder a un rol personalizado acceso a las páginas de Trusteed, añade

`Trusteed_AgenticCommerce::config` en **Sistema → Permisos → Roles de Usuario → [Rol] → Recursos del Rol**.

7. Rutas de administración

Nombre frontal: `trusteed` (definido en `etc/adminhtml/routes.xml`)

Patrón URL	Controlador	Descripción
<code>/trusteed/dashboard/index</code>	<code>Controller/Adminhtml/Dashboard/Index</code>	Host SPA del panel
<code>/trusteed/health/index</code>	<code>Controller/Adminhtml/Health/Index</code>	SPA de salud de la tienda
<code>/trusteed/ventas/index</code>	<code>Controller/Adminhtml/Ventas/Index</code>	SPA de ventas de agentes
<code>/trusteed/agentes/index</code>	<code>Controller/Adminhtml/Agentes/Index</code>	SPA de directorio de agentes
<code>/trusteed/reglas/index</code>	<code>Controller/Adminhtml/Reglas/Index</code>	SPA de reglas
<code>/trusteed/pagos/index</code>	<code>Controller/Adminhtml/Pagos/Index</code>	SPA de métodos de pago
<code>/trusteed/seguridad/index</code>	<code>Controller/Adminhtml/Seguridad/Index</code>	SPA de seguridad
<code>/trusteed/ajustes/index</code>	<code>Controller/Adminhtml/Ajustes/Index</code>	SPA de ajustes
<code>/trusteed/setup/wizard</code>	<code>Controller/Adminhtml/Setup/Wizard</code>	Asistente de Configuración
<code>/trusteed/setup/save</code>	<code>Controller/Adminhtml/Setup/Save</code>	Acción de guardado del asistente
<code>/trusteed/setup/introspecttoken</code>	<code>Controller/Adminhtml/Setup/IntrospectToken</code>	Introspección de token AJAX
<code>/trusteed/token/issue</code>	<code>Controller/Adminhtml/Token/Issue</code>	Emite token embebido (POST)
<code>/trusteed/support/submit</code>	<code>Controller/Adminhtml/Support/Submit</code>	Envío de formulario de soporte

8. Rutas de frontend

Nombre frontal: `nlweb` (definido en `etc/frontend/routes.xml`). Tanto el `id` de la ruta como el `frontName` son `nlweb`, y no existe ninguna ruta de frontend `trusteed`.

Patrón URL	Controlador	Descripción
<code>/nlweb/products/index</code>	<code>Controller/Products/Index</code>	Endpoint de búsqueda de productos NLWeb (proxiado)
<code>/nlweb/wellknown/mcpmanifest</code>	<code>Controller/Wellknown/McpManifest</code>	Devuelve el JSON del manifiesto MCP

`/.well-known/mcp.json` es la URL canónica del manifiesto y la que usan los agentes. **No** se llega a ella a través del `frontName` `nlweb`: la resuelve `Router/WellKnownRouter.php`, un router propio registrado con `sortOrder=10` en `etc/frontend/di.xml`, que despacha directamente la acción `Controller/Wellknown/McpManifest`. La ruta `/nlweb/wellknown/mcpmanifest` de la tabla anterior es ese mismo controlador alcanzado por el `frontName` normal, y existe sólo como alternativa para servidores web a los que no se les puede hacer reescribir la ruta con punto `/.well-known/`.

9. Servicios

EnforcementClient

Clase: `Trusteed\AgenticCommerce\Service\EnforcementClient`

Cliente HTTP para la API de evaluación de reglas de Trusteed.

Método	Devuelve	Descripción
<code>evaluate(array \$payload): string</code>	<code>ALLOW</code> <code>BLOCK</code> <code>ESCALATE</code>	Llama a <code>POST /v1/rules/evaluate</code> . En error de transporte, prueba primero la válvula de seguridad offline y después devuelve <code>BLOCK</code> (modo enforce) o <code>ALLOW</code> (modo observe)
<code>getDidResolver(string \$merchantId): array</code>	<code>array<{did, publicKeyJwk}></code>	Obtiene el mapa DID de agente → clave pública del snapshot. Array vacío en fallo
<code>getRules(string \$merchantId): array</code>	<code>array<{ruleCode, params, mode, enabled}></code>	Obtiene la configuración de reglas del snapshot
<code>consumeNonce(string \$agentDid, string \$jti, int \$exp): array</code>	<code>{outcome, reason, httpStatus}</code>	Registra un nonce de un solo uso para protección contra replay

Formato de firma (estilo Stripe):

```
X-Trusteed-Signature: t=<unix-timestamp>,s=<hmac-sha256-hex>
```

donde el HMAC se calcula sobre `"<timestamp>.<rawBody>"`.

AgentTokenVerifier

Clase: `Trusteed\AgenticCommerce\Service\AgentTokenVerifier`

Verifica tokens JWT de agente firmados con Ed25519:

1. Analiza la cabecera/payload del JWT (decodificación base64url directa, sin librería)
2. Busca la clave pública del agente en el snapshot (`getDidResolver`)
3. Verifica la firma Ed25519 usando `sodium_crypto_sign_verify_detached` (o fallback `paragonie/sodium_compat`)
4. Valida las claims `exp` , `iat` , `iss` , `aud`
5. Llama a `consumeNonce` para protección contra replay

`CartSignals`

Clase: `Trusted\AgenticCommerce\Service\CartSignals`

Extrae señales de nivel de carrito de un presupuesto Magento para incluirlas en el payload de `/v1/rules/evaluate` :

- Total del carrito
- Número de artículos
- IDs de categoría de producto
- Metadatos del agente de los atributos personalizados del presupuesto

`AgentHistoryFetcher`

Clase: `Trusted\AgenticCommerce\Service\AgentHistoryFetcher`

Obtiene el historial de pedidos del agente desde la API de Trusted para rellenar el campo de contexto `agentHistory` en `/v1/rules/evaluate` .

10. Motor de cumplimiento

Flujo

```
sales_model_service_quote_submit_before
  ↓
CheckoutSubmitBefore::execute()
  ↓
¿Es un pedido de agente? (la sesión de checkout tiene trustee_agent_token)
  ↓ sí
AgentTokenVerifier::verify()
  ↓ VALID / INVALID / UNVERIFIED
EnforcementClient::evaluate({
  merchantId, agentId, orderContext,
  platform: "MAGENTO",
  installationId, timestamp
})
  ↓
ALLOW    → continuar (el pedido se crea normalmente)
BLOCK     → lanzar LocalizedException (el pedido NO se crea)
ESCALATE  → congelar presupuesto (is_active=0), sellar flags HITL, lanzar LocalizedException
```

Los checkouts de clientes humanos también pasan por `evaluate()`, con `agentId` a `null`, así que sus reglas de comerciante también se les aplican.

ESCALATE (R043 HITL)

Cuando `evaluate()` devuelve `ESCALATE`:

1. `R043HitlGate::buildFreezePayload()` extrae el código de regla, motivo e ID de evaluación
2. El presupuesto se marca con metadatos personalizados:
 - `trusteed_hitl_pending = 1`
 - `trusteed_hitl_rule_code = <ruleCode>`
 - `trusteed_hitl_reason = <reason>`
 - `trusteed_hitl_evaluation_id = <evaluationId>`
3. El presupuesto `is_active` se establece en `0` (evita la recaptura del cliente)
4. Se lanza una `LocalizedException`, por lo que Magento no crea el pedido
5. El intento aparece en el panel de Trusteed para revisión del comerciante

Modo de fallo

Cuando falla la llamada a `evaluate()` (error de transporte, respuesta que no es 2xx o una URL base de API rechazada), el módulo prueba primero la válvula de seguridad offline. Comprueba el último snapshot de reglas con R014 (solo la comprobación de país), R018, R019, R020, R025, R027, R028, R029 y R030, y devuelve `BLOCK` si coincide alguna. Si no coincide ninguna, decide el modo de fallo:

Valor de configuración	Comportamiento
<code>enforce</code> (predeterminado)	Devuelve <code>BLOCK</code> . El pedido es rechazado
<code>observe</code>	Devuelve <code>ALLOW</code> . El pedido procede

11. Bandeja de salida de webhooks

Formato del payload de entrega

Cada entrada se entrega con `POST <api_base_url>/api/v1/webhook/magento/<connection_id>`. Este es el cuerpo de un evento de estado del pedido (`sales_order_save_after`):

```
{
  "event_id": "<uuid-v4>",
  "event_type": "order_created",
  "entity_id": 1,
  "increment_id": "000000001",
  "composite_id": "MAG:1",
  "store_view_code": "default",
  "updated_at": "2026-06-18T10:00:00+00:00",
  "payload": {
    "grand_total": 99.99,
    "status": "pending",
    "state": "new",
    "customer_email": null,
    "agent_id": null
  }
}
```

`customer_email` es siempre `null`, porque el payload omite los datos personales. `agent_id` contiene la identidad verificada del agente en los pedidos de agentes y es `null` en los checkouts de clientes humanos.

Cabeceras de firma

```
Authorization: Bearer <integration token>
X-Trusteed-Signature: <hmac-sha256 en hexadecimal>
X-Trusteed-Timestamp: <segundos unix>
X-Trusteed-Nonce: <32 caracteres hexadecimales>
X-Trusteed-Webhook-Secret-Version: 1
```

Entrada HMAC, con el secreto de webhook como clave:

```
"<timestamp>.<nonce>.<secretVersion>.<rawBody>"
```

Programación de reintentos

Retroceso exponencial, calculado por `Cron/DrainOutbox.php::backoffDelaySeconds()`:

```
espera = min(2 × 2^retry_count, 3600) ± 20 % de jitter
```

La base son **2 segundos** (`BACKOFF_BASE_SECONDS`), el techo **3600 segundos** (`BACKOFF_MAX_SECONDS`), y se aplica un jitter simétrico de $\pm 20\%$ (`BACKOFF_JITTER_RATIO = 0.20`) para que los reintentos de varios procesos no se agolpen a la vez. La espera nunca baja de la base de 2 segundos. El cron no duerme: sella `next_attempt_at` y termina.

Intento (<code>retry_count</code>)	Espera nominal hasta el siguiente intento
0	2 s
1	4 s
2	8 s
3	16 s
...	se duplica cada vez
11 y siguientes	3600 s (techo)

Tras **8 intentos** (`OutboxRepository::MAX_RETRIES = 8`) la fila se marca como `dead`. Las entradas `dead` no se reintentan. Cada pasada del vaciador procesa como máximo 50 filas (`BATCH_SIZE`) y se detiene a los 55 segundos (`MAX_RUNTIME_SECONDS`).

12. Verificación de token de agente

Los tokens de agente son JWTs firmados con Ed25519 (algoritmo `EdDSA`, curva `Ed25519`).

Claims del token

`iss`, `aud`, `exp`, `iat`, `nonce` y `jti` son todos **obligatorios**. Un token al que le falte cualquiera de ellos se rechaza como `invalid` (véase `Service/AgentTokenVerifier.php`).

Claim	Tipo	Cómo se valida
<code>iss</code>	string	DID del agente. Debe coincidir con el DID derivado del <code>kid</code> de la cabecera, como guarda anti key-confusion
<code>aud</code>	string	Debe ser el literal <code>trusted</code> . (No es el Merchant ID)
<code>merchantId</code>	string	Opcional. Si viene, debe coincidir con el Merchant ID configurado en la tienda
<code>exp</code>	timestamp Unix	Vencimiento. Se rechaza en cuanto <code>ahora > exp + 30</code> (30 segundos de tolerancia de reloj)
<code>iat</code>	timestamp Unix	Momento de emisión. Se rechaza en cuanto <code>ahora - iat > 330</code> (<code>MAX_AGE_SECONDS</code>)
<code>nonce</code>	string	Obligatorio, de 16 a 64 caracteres
<code>jti</code>	string	Identificador de un solo uso, debe cumplir <code>/^[A-Za-z0-9_-]{16,128}\$/</code> ; si falta → <code>missing_jti</code>

El verificador no lee `sub` ni `platform`. La antigüedad máxima del token es por tanto de **330 segundos** desde `iat`, no de 300.

Resultados de la verificación

Resultado	Significado
<code>VERIFIED</code>	Firma válida, claims válidas, nonce no reproducido
<code>INVALID</code>	Firma inválida, token vencido o nonce ya usado
<code>UNVERIFIED</code>	Sin token o token no analizable

Resolución de clave pública

Las claves públicas de los agentes se obtienen del snapshot de cumplimiento (`GET /v1/rules/snapshot/<merchantId>`) como conjunto JWK. El snapshot se almacena en caché en memoria durante la duración de la solicitud para evitar llamadas API repetidas.

13. Manifiesto MCP

Endpoint: `GET /.well-known/mcp.json` Controlador:

`Trusted\AgenticCommerce\Controller\Wellknown\McpManifest` Constructor:

`Trusted\AgenticCommerce\Model\Manifest\Builder`

El manifiesto indica a los agentes IA qué capacidades expone su tienda. Está firmado con una clave Ed25519 provisionada por Trusteed.

Campos del manifiesto

```
{
  "schema_version": "1.0",
  "issuer": "https://api.trusteed.xyz",
  "merchant_id": "<merchant-id>",
  "store_views": [
    { "code": "default", "base_url": "https://su-tienda.com" },
    { "code": "fr", "base_url": "https://su-tienda.fr" }
  ],
  "capabilities": ["checkout", "catalog_search", "order_status"],
  "updated_at": "<iso8601>",
  "signature": {
    "jws": "<jws-compacto-desacoplado>",
    "kid": "<id-de-clave>",
    "alg": "EdDSA",
    "signed_at": "<iso8601>"
  }
}
```

Notas sobre la forma real:

- `capabilities` es un array plano de tres cadenas (`checkout` , `catalog_search` y `order_status`). No es un objeto de banderas de características y no incluye ninguna lista de métodos de pago.
- `signature` es un **objeto** (`jws` / `kid` / `alg` / `signed_at`), no una cadena JWS suelta.
- `issuer` es la URL base configurada de la API de Trusteed. No existen los campos `store_url` , `connection_id` , `platform` , `mcp_endpoint` ni `issued_at` .
- `store_views[]` enumera cada vista de tienda publicada con su URL base, para que los agentes puedan hacer coincidencia por prefijo más largo entre varios dominios.
- El `signed_payload` que devuelve el backend se sirve **literalmente**: el backend es la autoridad sobre `issuer` , `merchant_id` y `capabilities` (ADR-014), y servir sus bytes exactos es lo que hace que el JWS desacoplado verifique contra lo que recibió el agente.
- `schema_version` es la clave que busca `bin/magento trusteed:check-webserver` para decidir si el endpoint está sirviendo un manifiesto de verdad.

14. Atributos de extensión

El módulo añade atributos de extensión a `Magento\Sales\Api\Data\OrderInterface` :

Atributo	Tipo	Descripción
<code>trusteed_receipt_uri</code>	string	URI del TrustReceipt
<code>trusteed_receipt_status</code>	string	Estado del recibo. El módulo establece <code>signed</code> al guardar por primera vez la URI del recibo

Definidos en `etc/extension_attributes.xml`. Cargados/guardados mediante `Plugin/Sales/OrderExtensionAttribute.php` y `Plugin/Repository/OrderRepositoryPlugin.php`.

15. Endpoints de API invocados

El módulo realiza llamadas HTTPS salientes a la API de Trusteed. Todas las llamadas requieren HTTPS y son validadas por `ApiBaseUrlValidator` (guardia SSRF).

Método	Ruta	Cuándo	Autenticación	Timeout
POST	/v1/rules/evaluate	En cada intento de pago	X-Trusteed-Installation-Id + X-Trusteed-Signature (HMAC)	5 s
GET	/v1/rules/snapshot/ <merchantId>	Por fallo de caché de solicitud	X-Trusteed-Installation-Id + X-Trusteed-Signature (HMAC)	5 s
POST	/v1/agent-events/nonce-consume	Tras la verificación del token	X-Trusteed-Installation-Id + X-Trusteed-Signature (HMAC)	5 s
GET	/.well-known/jwks.json	Verificación de la firma del snapshot	ninguna (claves públicas)	5 s
POST	/api/v1/webhook/magento/ <connectionId>	Entrega de la bandeja de salida	Bearer + X-Trusteed-Signature, X-Trusteed-Timestamp, X-Trusteed-Nonce, X-Trusteed-Webhook-Secret-Version	10 s
POST	/api/v1/internal/magento/lag-heartbeat	Cada minuto (cron de monitor de latencia)	X-Trusteed-Connection-Id + X-Trusteed-Timestamp + X-Trusteed-Signature (HMAC interno)	10 s

Método	Ruta	Cuándo	Autenticación	Timeout
POST	/api/v1/internal/magento/event	Parche de datos del evento de instalación	X-Trusteed-Connection-Id + X-Trusteed-Timestamp + X-Trusteed-Signature (HMAC interno)	10 s
POST	/api/v1/internal/magento/manifest/sign	Construcción del manifiesto (firma remota, ADR-050)	X-Trusteed-Connection-Id + X-Trusteed-Timestamp + X-Trusteed-Signature (HMAC interno)	5 s
POST	/api/v1/enforcement/capabilities	Una vez por versión del juego de capacidades	HMAC en el campo signature del cuerpo	3 s
POST	/api/v1/auth/introspect	Introspección de token del asistente	token bearer bajo prueba	5 s
POST	/platform/magento/validate-connect-token	Conexión del Asistente de Configuración	token de conexión	5 s
GET	/api/v1/trust/overview?merchantId=<id>	Render de la pestaña de salud	X-Trusteed-Signature (HMAC)	6 s
POST	/api/v1/coupon-attempts-failed	Observador de cupón inválido	X-Trusteed-Signature (HMAC)	1,5 s
POST	/api/v1/checkout-failures	Observador de pago fallido	X-Trusteed-Signature (HMAC)	1,5 s
GET	/api/v1/checkout-failures/count	Señales de historial del agente	X-Trusteed-Signature (HMAC)	3 s

Método	Ruta	Cuándo	Autenticación	Timeout
GET	/api/v1/agents/ <agentIdHash>/cross- merchant-abuse-check	Señales de historial del agente	X-Trusteed-Signature (HMAC)	3 s
GET	/api/v1/merchants/ <merchantId>/disputes/ count	Señales de historial del agente	X-Trusteed-Signature (HMAC)	3 s
GET	/api/v1/health	Sonda de alcance de ApiBaseUrlValidator	ninguna	5 s
POST	/v1/embed/magento/issue-token	Emisión de token del SPA de administración	X-Embed-Magento-Secret (secreto de embed por conexión)	10 s
POST	/v1/embed/support/report	«Enviar diagnóstico» del administrador	Authorization: Bearer (token de integración)	10 s

Los timeouts no son uniformes. Cambian según quién llama, tal como se lista arriba:

EnforcementClient y ApiBaseUrlValidator usan 5 s, Manifest\Builder 5 s (SIGN_TIMEOUT_SECONDS), Webhook\SignaturePublisher 10 s (TIMEOUT_SECONDS), y sirve además el latido y la llamada del evento de instalación), Adminhtml\Token\Issue y Adminhtml\Support\Submit 10 s, Block\Adminhtml\Health\Tab 6 s (SCORE_HTTP_TIMEOUT), AgentHistoryFetcher 3 s (HTTP_TIMEOUT_SECONDS) y CapabilitiesReporter 3 s. Los dos observadores de «disparar y olvidar» son los más ajustados: 1500 ms en total y 800 ms para conectar (CURLOPT_TIMEOUT_MS / CURLOPT_CONNECTTIMEOUT_MS), de modo que un backend lento no pueda retrasar un pago. ApiBaseUrlValidator además limita el tiempo de conexión a 5 s (CONNECT_TIMEOUT_SECONDS).

La verificación TLS entre pares siempre está habilitada (CURLOPT_SSL_VERIFYPEER=true, CURLOPT_SSL_VERIFYHOST=2) y las redirecciones HTTP están deshabilitadas (CURLOPT_FOLLOWLOCATION=false). Manifest\Builder aplica además una lista cerrada de hosts permitidos antes de enviar el secreto HMAC interno a ningún sitio.

16. Modelo de seguridad

Protección SSRF

`Model/Security/ApiBaseUrlValidator.php` valida la `api_base_url` configurable por el administrador contra una lista de hosts de API de Trusted conocidos y permitidos. Cualquier intento de cambiar la URL de API a un host no permitido es rechazado antes de enviar cualquier payload firmado.

Fortalecimiento TLS

Todas las llamadas curl salientes aplican:

- Solo esquema HTTPS (`CURLPROTO_HTTPS`)
- Verificación TLS de par y host
- Sin seguimiento de redirecciones

Firma HMAC

Las llamadas a `POST /v1/rules/evaluate` están firmadas con HMAC-SHA256 en formato estilo Stripe: `t=<timestamp>,s=<hex>`. La entrada de firma es `"<timestamp>.<rawBody>"`. Las entregas de webhook usan las cabeceras y la entrada de firma distintas descritas en [Bandeja de salida de webhooks](#).

Versionado del secreto de webhook

Cada entrada de la bandeja de salida guarda la versión del secreto de webhook vigente cuando se encoló, y la cabecera de entrega `X-Trusted-Webhook-Secret-Version` lleva esa versión. Rote los secretos así:

1. Actualice el secreto en el panel de Trusted
2. Pegue el nuevo secreto en la configuración de Magento
3. Incremente `Webhook Secret Version`

Protección contra replay

Los tokens de agente incluyen un claim `jti` (JWT ID). El módulo llama a `POST /v1/agent-events/nonce-consume` tras verificar cada token. Una respuesta 409 indica replay, y el módulo trata el token como `INVALID`.

17. Comandos de consola

Comando	Clase	Descripción
<code>trusted:check-webserver</code>	<code>Console/Command/CheckWebserver.php</code>	Pide <code>/.well-known/mcp.json</code> por la URL base insegura de la tienda y confirma que la respuesta es un manifiesto de verdad (comprueba que haya un <code>schema_version</code> de primer nivel). Si falla, imprime los fragmentos de reescritura para Nginx y Apache
<code>trusted:webhook:status</code>	<code>Console/Command/WebhookStatus.php</code>	Imprime estadísticas de la bandeja de salida: recuentos de pendientes, entregados y muertos, y antigüedad de la entrada pendiente más antigua

Ambos nombres están registrados en `etc/di.xml` bajo `Magento\Framework\Console\CommandListInterface`.

Uso:

```
bin/magento trusted:check-webserver
bin/magento trusted:webhook:status
```

18. Parches de datos

Clase de Parche	Propósito	Idempotente
<code>AddAgenticVisibleAttribute</code>	Añade el atributo EAV de producto <code>is_agentic_visible</code> (booleano, por defecto 1). Solo filtrado de catálogo de spec-050 FR-A-013. <code>Controller/Products/Index.php</code> sirve a los agentes únicamente los productos marcados con <code>1</code> . No es una regla: ninguna regla CEL lo lee	Sí
<code>DisableBridgeOnHyva</code>	Detecta temas Hyvä o PWA Studio y establece <code>trusted_general/features/webmcp_enabled = 0</code> para evitar conflictos JS del storefront	Sí
<code>EmitInstallEvent</code>	Llama a <code>POST /api/v1/internal/magento/event</code> para registrar la marca temporal de instalación y la versión de Magento en el panel de Trusted	Sí
<code>ReportSignalCapabilities</code>	Informa de qué señales de carrito puede proyectar esta instalación, vía <code>POST /api/v1/enforcement/capabilities</code> . Sin él, una regla cuya señal nunca llega devuelve <code>NO_SIGNAL</code> en cada pago: pasa en silencio mientras se muestra como ENFORCE	Sí

19. Configuración Di.xml

Entradas clave de inyección de dependencias:

```

<!-- EnforcementClient recibe el validador SSRF vía DI -->
<type name="Trusteed\AgenticCommerce\Service\EnforcementClient">
    <arguments>
        <argument name="urlValidator" xsi:type="object">
            Trusteed\AgenticCommerce\Model\Security\ApiBaseUrlValidator
        </argument>
    </arguments>
</type>

<!-- Comandos de consola -->
<type name="Magento\Framework\Console\CommandListInterface">
    <arguments>
        <argument name="commands" xsi:type="array">
            <item name="trusteed_check_webserver" xsi:type="object">
                Trusteed\AgenticCommerce\Console\Command\CheckWebserver
            </item>
            <item name="trusteed_webhook_status" xsi:type="object">
                Trusteed\AgenticCommerce\Console\Command\WebhookStatus
            </item>
        </argument>
    </arguments>
</type>

```

`Model\Webhook\OutboxRepository` se inyecta como **clase concreta**. No existe ninguna `OutboxRepositoryInterface` ni ninguna `<preference>` para ella, así que dependa de la clase.

Consulte `etc/di.xml` y `etc/frontend/di.xml` para la configuración completa.

20. Registro de eventos (Logging)

Todas las entradas de registro del módulo llevan el prefijo `[trusteed]` y se escriben en `var/log/system.log` (registrador predeterminado de Magento) en los siguientes niveles:

Nivel	Mensajes de ejemplo
<code>debug</code>	Acierto de caché del snapshot, nonce consumido ACCEPTED
<code>info</code>	Encole exitoso en bandeja de salida, webhook entregado
<code>warning</code>	Timeout de API, rechazo del guardia SSRF, desajuste de verificación HMAC, HTTP no-2xx en evaluate
<code>error</code>	Configuración obligatoria faltante, fallo de vaciado de bandeja de salida tras máximos reintentos

Para habilitar el registro de debug:

```
bin/magento config:set dev/debug/debug_logging 1
```

Atajos de grep para registros

```
# Todas las entradas de Trusteed
grep '\[trusted\]' var/log/system.log

# Solo problemas de entrega de bandeja de salida
grep '\[trusted\] webhook\|deliver\|dead\|retry' var/log/system.log

# Decisiones de cumplimiento
grep '\[trusted\] evaluate\|BLOCK\|ALLOW\|ESCALATE' var/log/system.log

# Problemas de tokens de agente
grep '\[trusted\] token\|nonce\|verify\|INVALID\|REPLAY' var/log/system.log
```